

certification is a limitation here, as the CA trusts another organisation.

Online vs offline CA: An online CA, usually referred to as intermediate CA, is responsible for the issuance and management of certificates to users or other intermediate CAs.

If the root CA is compromised, it can collapse the entire system. An offline CA is used only to add or remove an intermediate CA that is one level lower down in the hierarchy. It is usually powered off and disconnected from the network.

Cross-certification model CA: An alternative to the hierarchical model is the cross-certification model, also known as the web of trust model. Here we do not have single root dependency as the CAs are considered each other's peers. But configuration of this model over a period becomes a challenge.

Bridge model CA: This model was introduced to solve the cross-certification problem. Here, a single CA called the bridge CA combines two or more hierarchical models.

Registration authorities (RAs)

Registration is the process by which end users create an account with the CA and become authorised to request for certificates. RAs carry out identity validation and submit CSRs or certificate signing requests on behalf of end users to the CA, but they do not actually sign or issue certificates. That job is done only by CAs.

The registration function is delegated by the CA to one or more RAs. CAs may use a range of tests to ensure that a subject is who he or she claims to be. It is in the CA's interest to ensure that it only issues certificates to legitimate users, or its reputation will suffer.

Digital certificates

Digital certificates or DGs are used for identification and authentication purposes.

The DG is a wrapper for the public key and gives details of the user as well as certificate issuer or guarantor.

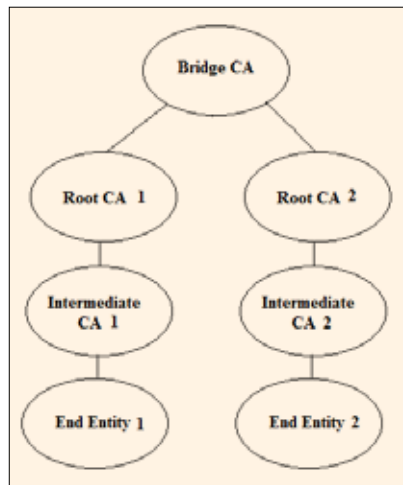


Figure 3: Bridge model CA (Credits: http://www.pkiglobe.org/pki_models.html)

Digital certificates are based on the X.509 standard approved by the International Telecommunications Union and standardised by the Internet Engineering Task Force (tools.ietf.org/html/rfc5280). PGP uses its own certificate standards.

Certificate signing requests or CSRs

To obtain a certificate, a user needs to generate a special request and submit it to the CA. This is called a certificate signing request or CSR.

The CSR is a Base64 ASCII file containing the information the user needs in the certificate, including its public key, such as:

- Fully qualified domain name
- City, state, country
- Email address

The CA reviews the certificate and validates the information. If the request is accepted, the CA signs the certificate and sends it to the user.

Certificate policy

A certificate policy applies the rules needed to generate a certificate. Different certificates serve different purposes. Information in a certificate policy includes:

- Key management requirements
- Lifetime of the certificate

- Rules for exporting the private key
- Private and public key minimum lengths

Certificate attributes

The X.509 standard defines the attributes a certificate must have.

- **Serial number:** Unique number to identify the certificate within the domain of its CA.
- **Version number:** Version of X.509 standard the certificate complies with.
- **Signature algorithm:** Algorithm used by the CA to sign.
- **Issuer:** Name of the CA that has signed the certificate.
- **Valid from/to:** Validation period of the certificate – often it's set to one year.
- **Subject:** Name of the certificate holder.
- **Public key:** Holds the public key and information such as key size, algorithm, etc.
- **Extensions:** X.509 version 3 has the option to define additional/extended attributes such as email, algorithms, intended key usage, etc.
- **Signature value:** This ensures the validity of the certificate.
- **Subject alternative name or SAN:** The SAN extension field is the preferred mechanism to identify DNS or names of the host. If the value is present in SAN, the subject (e.g., the browser) should validate it ignoring the CN (common name). But the challenge here is that if a new domain is added, a new certificate needs to be issued. Whereas if a wildcard is preset in the SAN, such as **.abc.com*, the certificate issued to the parent accepts all the valid sub-domains.

Types of certificates

Domain validation (DV) certificate:

Provides the ownership of the domain and includes only the domain name. It is highly vulnerable. DV certificates are the quickest and least expensive certificates to acquire.